

UCF



Stands For Opportunity

CIS3360: Security in Computing

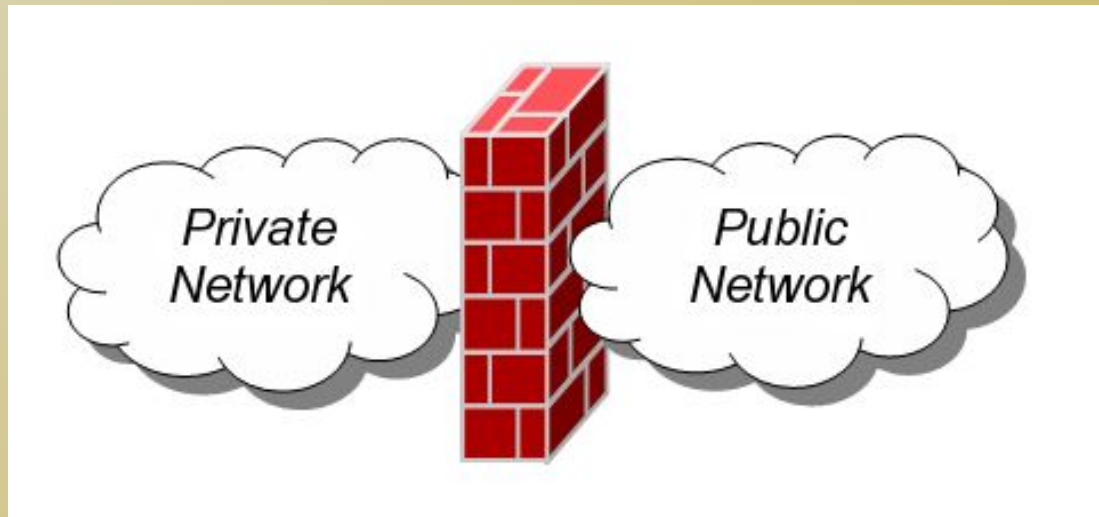
Chapter 6 : Network Security II ***- Firewall, Tunneling, Intrusion Detection***

Cliff Zou
Spring 2012

Firewall

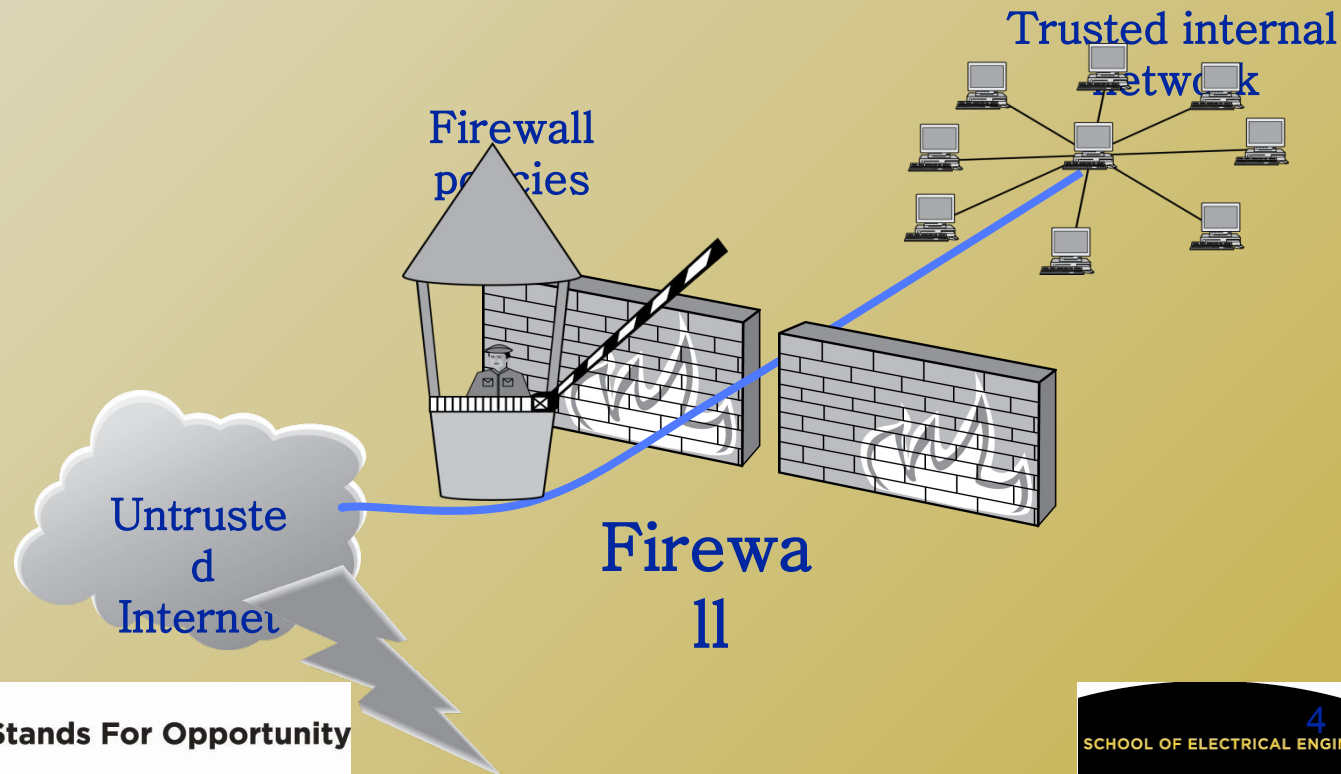
Firewalls

- ❑ A **firewall** is an integrated collection of security measures designed to prevent unauthorized electronic access to a networked computer system.
- ❑ A network firewall is similar to firewalls in building construction, because in both cases they are intended to isolate one "network" or "compartment" from another.



Firewall Policies

- To protect private networks and individual machines from the dangers of the greater Internet, a firewall can be employed to filter incoming or outgoing traffic based on a predefined set of rules called **firewall policies**.



Policy Actions

- ❑ Packets flowing through a firewall can have one of three outcomes:
 - ❑ **Accepted:** permitted through the firewall
 - ❑ **Dropped:** not allowed through with no indication of failure
 - ❑ **Rejected:** not allowed through, accompanied by an attempt to inform the source that the packet was rejected
- ❑ Policies used by the firewall to handle packets are based on several properties of the packets being inspected, including the protocol used, such as:
 - ❑ TCP or UDP
 - ❑ **the source and destination IP addresses**
 - ❑ **the source and destination ports**
 - ❑ the application-level payload of the packet (e.g., whether it contains a virus).

Blacklists and White Lists

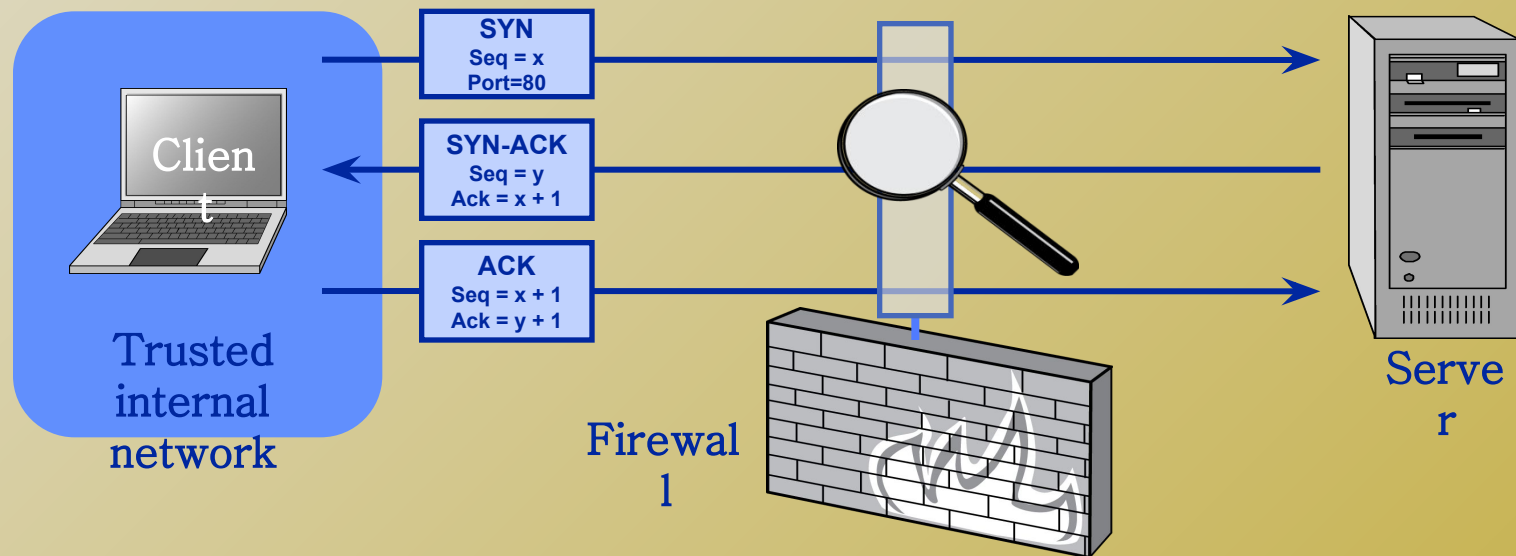
- ❑ Two fundamental approaches to creating firewall policies (or rulesets)
- ❑ **Blacklist** approach (default-allow)
 - ❑ All packets are allowed through except those that fit the rules defined specifically in a blacklist.
 - ❑ Pros: flexible in ensuring that service to the internal network is not disrupted by the firewall
 - ❑ Cons: unexpected forms of malicious traffic could go through
- ❑ **Whitelist** approach (default-deny)
 - ❑ Packets are dropped or rejected unless they are specifically allowed by the firewall
 - ❑ Pros: A safer approach to defining a firewall ruleset
 - ❑ Cons: must consider all possible legitimate traffic in rulesets

Firewall Types

- **packet filters (stateless)**
 - If a packet matches the packet filter's set of rules, the packet filter will drop or accept it
- **"stateful" filters**
 - it maintains records of all connections passing through it and can determine if a packet is either the start of a new connection, a part of an existing connection, or is an invalid packet.
- **application layer**
 - It works like a **proxy** it can “understand” certain applications and protocols.
 - It may inspect the contents of the traffic, blocking what it views as inappropriate content (i.e. websites, viruses, vulnerabilities, ...)

Stateless Firewalls

- ❑ A stateless firewall doesn't maintain any remembered context (or "state") with respect to the packets it is processing. Instead, it treats each packet attempting to travel through it in isolation without considering packets that it has processed previously.

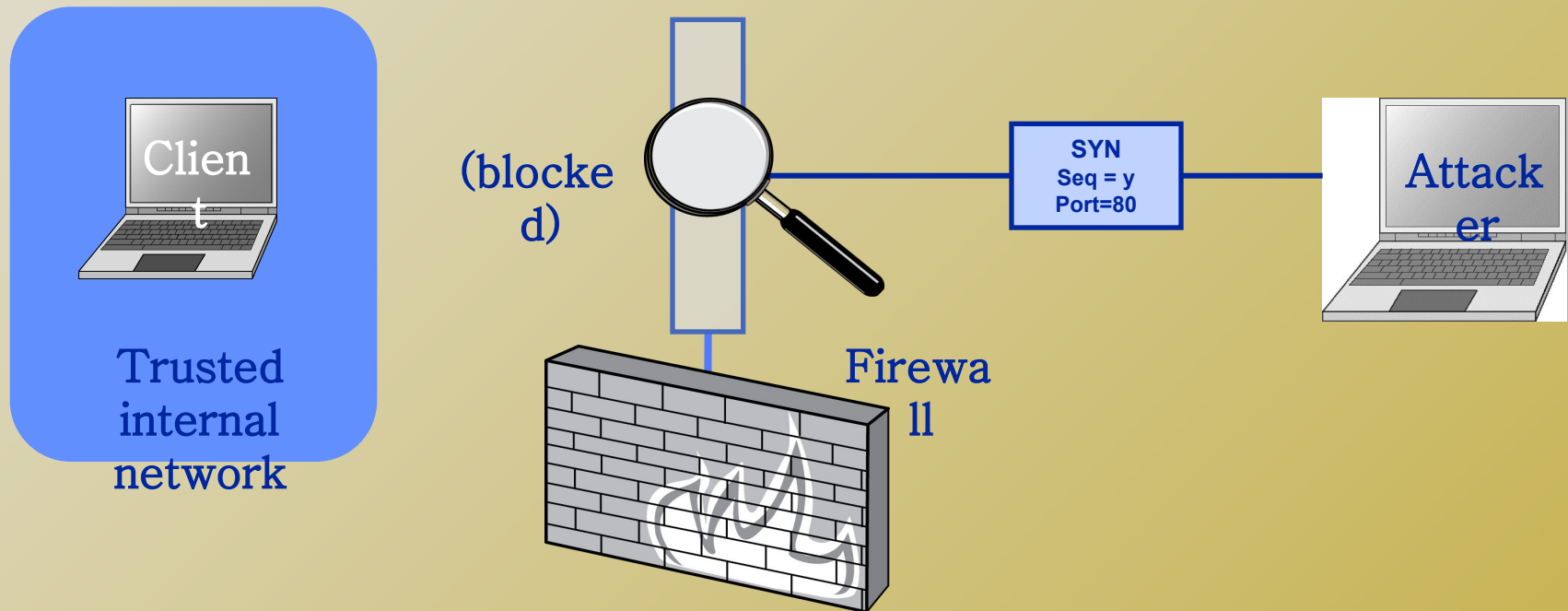


Allow outbound SYN packets, destination
port=80

Allow inbound SYN-ACK packets, source
port=80

Stateless Restrictions

- Stateless firewalls may have to be fairly restrictive in order to prevent most attacks.



Allow outbound SYN packets, destination port=80

Drop inbound SYN packets,

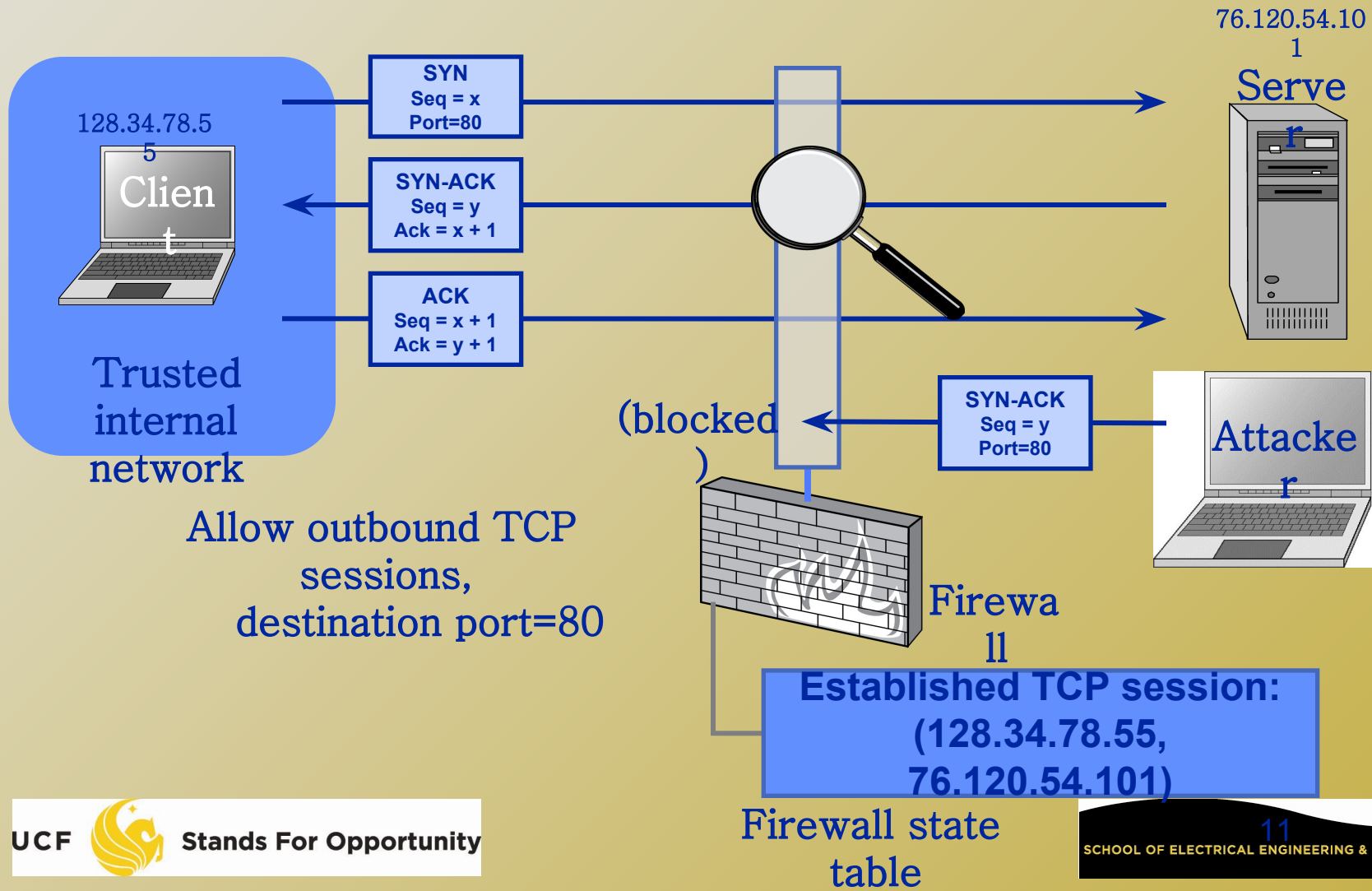
Allow inbound SYN-ACK packets, source port=80

Statefull Firewalls

- ❑ **Stateful firewalls** can tell when packets are part of legitimate sessions originating within a trusted network.
- ❑ Stateful firewalls maintain tables containing information on each active connection, including the IP addresses, ports, and sequence numbers of packets.
- ❑ Using these tables, stateful firewalls can allow only inbound TCP packets that are in response to a connection initiated from within the internal network.

Statefull Firewall Example

- Allow only requested TCP connections:

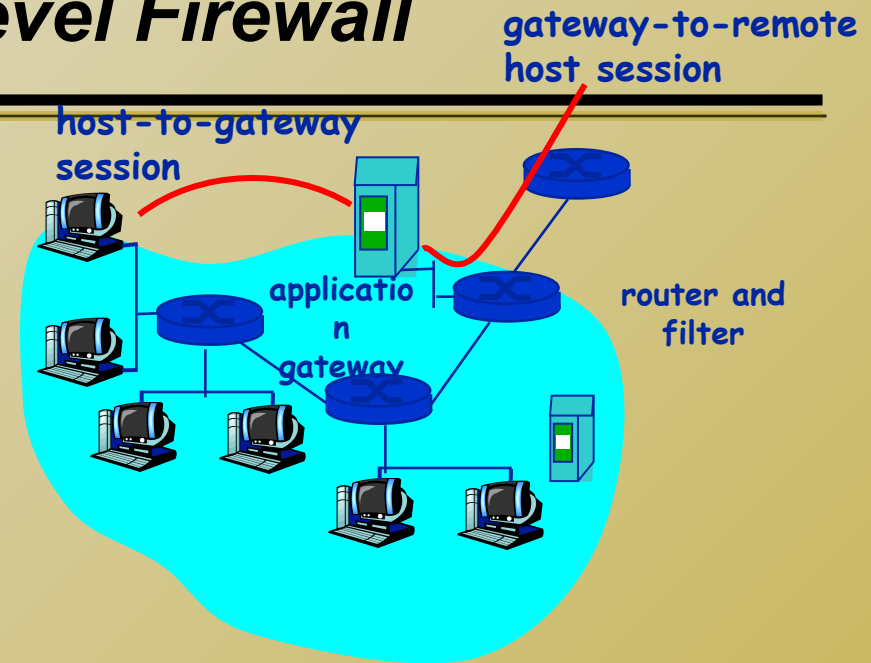


-
- ❑ TCP-based connections are easy to check
 - ❑ TCP SYN packet

 - ❑ UDP-based traffic is not so clear
 - ❑ There is no UDP connection set up
 - ❑ Treat a UDP session starts when a legitimate UDP packet is allowed through the firewall (such as from inside to outside)
 - ❑ Session is defined by (source IP, source port, dest IP, dest port)

Application-level Firewall

- ❑ Filters packets on application data as well as on IP/TCP/UDP fields.
- ❑ Example: allow select internal users to telnet outside.



1. Require all telnet users to telnet through gateway.
2. For authorized users, gateway sets up telnet connection to dest host. Gateway relays data between 2 connections
3. Router filter blocks all telnet connections not originating from gateway.

- r Example: block user access to know porn websites
 - m Check if the Web URL is in a "black-list"

Firewall on Windows and Linux

- ❑ On Linux, Iptables is used to provide firewall function
- ❑ <http://en.wikipedia.org/wiki/Iptables>
- ❑ On Windows, use “control panel”❑ “Windows Firewall”

Tunnels

- ❑ The contents of TCP packets are not normally encrypted, so if someone is eavesdropping on a TCP connection, he can often see the complete contents of the payloads in this session.
- ❑ One way to prevent such eavesdropping without changing the software performing the communication is to use a **tunneling protocol**.
- ❑ In such a protocol, the communication between a client and server is automatically encrypted, so that useful eavesdropping is infeasible.

Tunneling Prevents Eavesdropping

- ❑ Packets sent over the Internet are automatically encrypted.

Client

Server

Tunneling protocol
(does end-to-end encryption and decryption)

Untrusted Internet

TCP/I
P

TCP/I
P

Payloads are encrypted here

16

Secure Shell (SSH)

- ❑ **A secure interactive command session:**
- ❑ The client connects to the server via a TCP session.
- ❑ The client and server exchange information on administrative details, such as supported encryption methods and their protocol version, each choosing a set of protocols that the other supports.
 - ❑ Example: check ssh client software to see what are supported.
- ❑ The client and server initiate a secret-key exchange to establish a shared secret session key, which is used to encrypt their communication (but not for authentication). This session key is used in conjunction with a chosen block cipher (typically AES, 3DES) to encrypt all further communications.

-
- ❑ The server sends the client a list of acceptable forms of authentication, which the client will try in sequence.
 - ❑ Password based authentication
 - ❑ Public-key authentication method
 - ❑ Client sends the server its public key
 - ❑ The server then checks if this key is stored in its list of authorized keys. If so, the server encrypts a challenge using the client's public key and sends it to the client
 - ❑ The client decrypts the challenge with its private key and responds to the server, proving its identity

IPSec

- ❑ IPSec defines a set of protocols to provide confidentiality and authenticity for IP packets
- ❑ **Authentication Header (AH)**
 - ❑ provide connectionless integrity and data origin authentication for IP datagrams
 - ❑ provides protection against replay attacks
 - ❑ No confidentiality (packets are still unencrypted)
- ❑ **Encapsulating Security Payload (ESP)**
 - ❑ provide confidentiality, data-origin authentication, connectionless integrity, and limited traffic-flow confidentiality.
 - ❑ Port numbers are encrypted, poses challenge for NAT
- ❑ <http://en.wikipedia.org/wiki/IPsec>

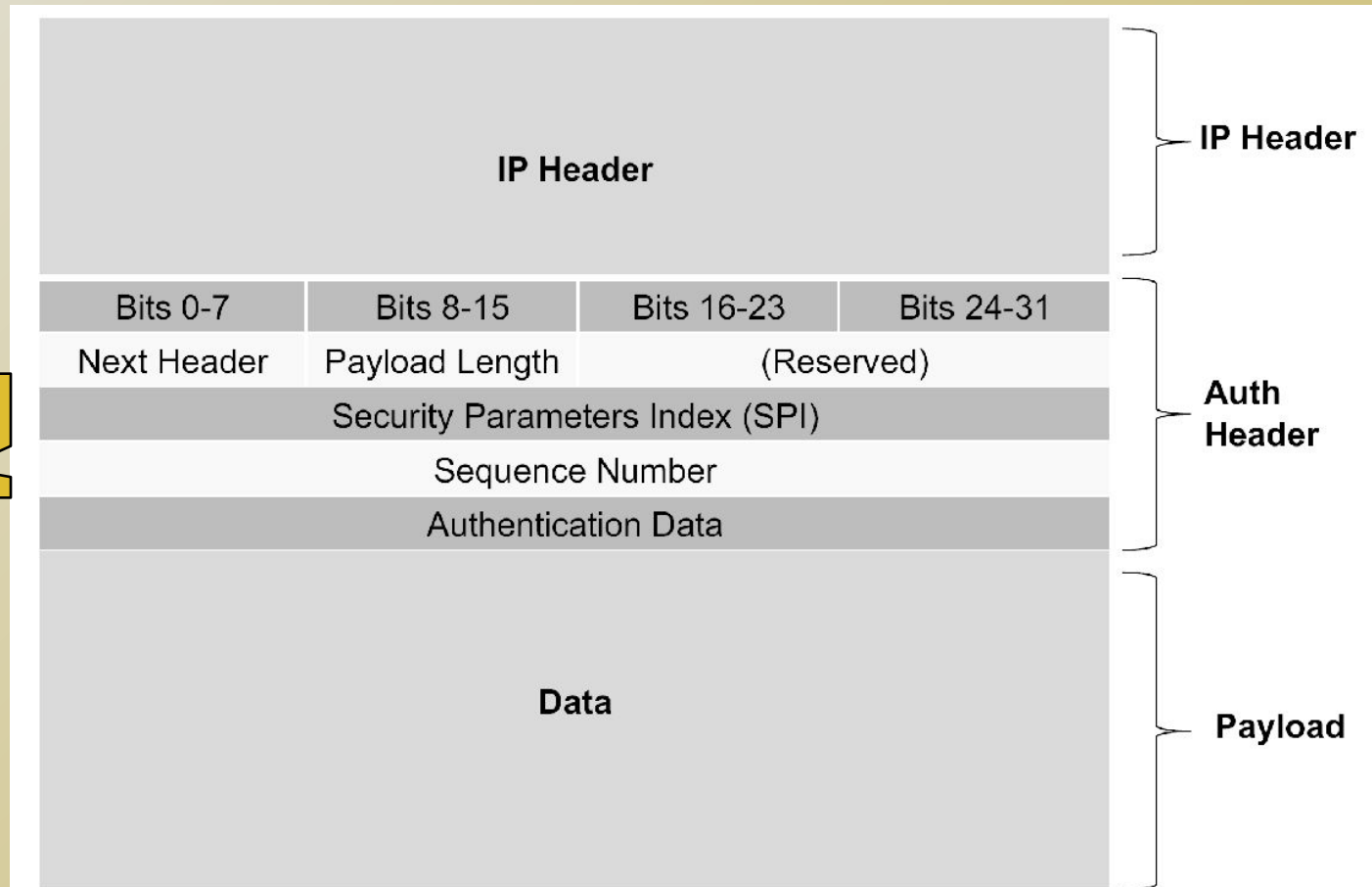


Figure 6.15: The authentication header.

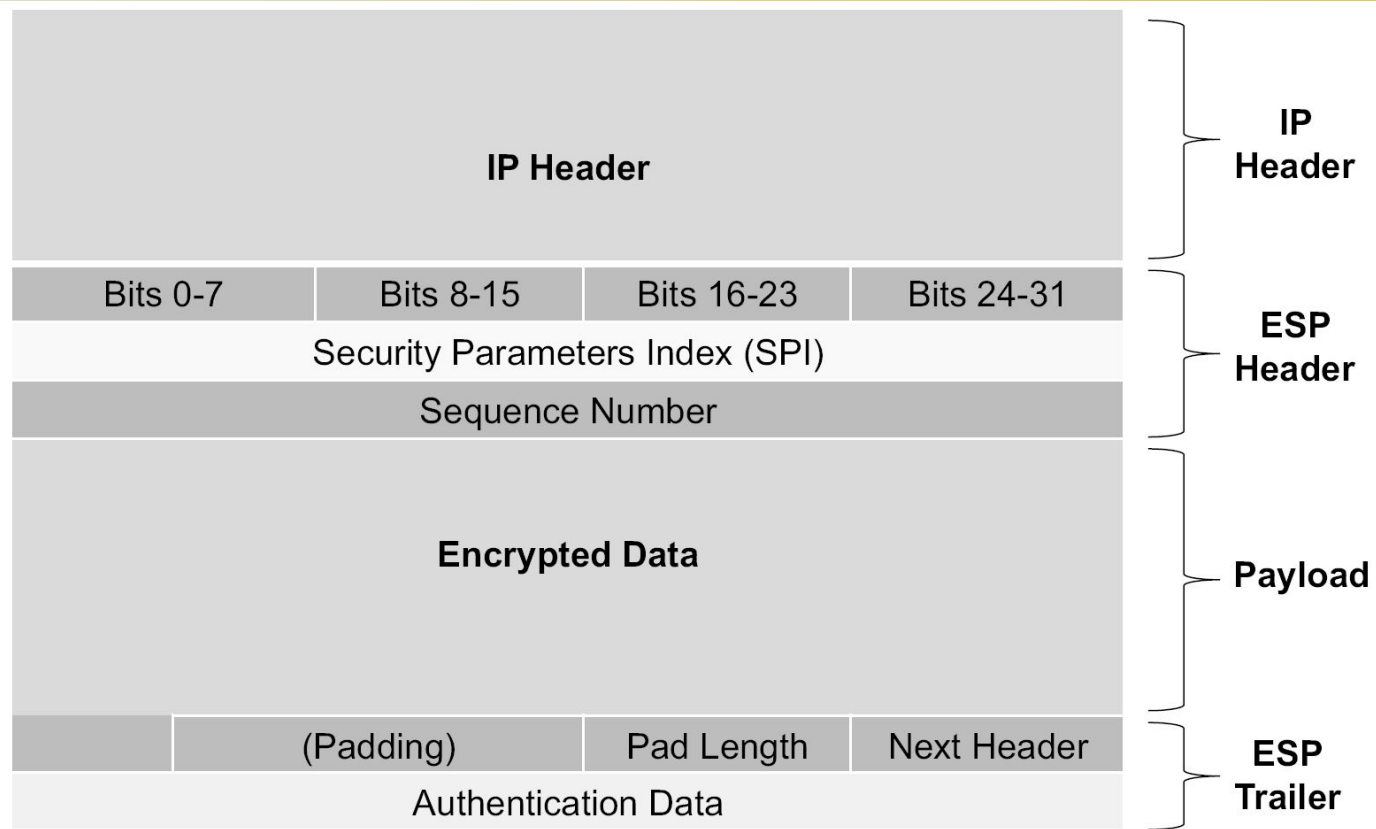


Figure 6.16: The ESP header.

Virtual Private Networking (VPN)

- ❑ **Virtual private networking (VPN)** is a technology that allows private networks to be safely extended over long physical distances by making use of a public network, such as the Internet, as a means of transport.
- ❑ VPN provides guarantees of data confidentiality, integrity, and authentication, despite the use of an untrusted network for transmission.
- ❑ There are two primary types of VPNs, **remote access VPN** and **site-to-site VPN**.

Types of VPNs

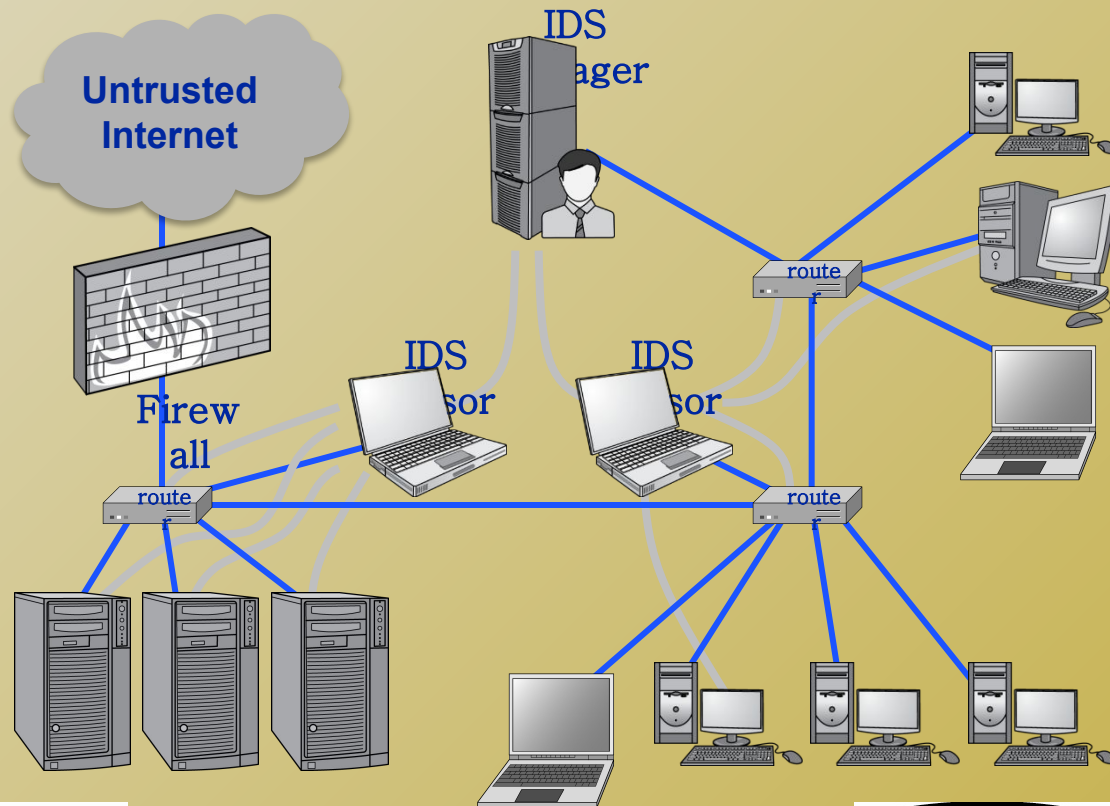
- ❑ **Remote access** VPNs allow authorized clients to access a private network that is referred to as an **intranet**.
 - ❑ E.g., UCF VPN. Computer has internal IP when connected.
 - ❑ Set up a VPN endpoint, **network access server (NAS)**
 - ❑ Clients install VPN client software on their machines.
- ❑ **Site-to-site** VPN solutions are designed to provide a secure bridge between two or more physically distant networks.
 - ❑ Before VPN, organizations wishing to safely bridge their private networks purchased expensive leased lines to directly connect their intranets with cabling.

Intrusion Detection Systems

- ❑ **Intrusion**
 - ❑ Actions aimed at compromising the security of the target (confidentiality, integrity, availability of computing/networking resources)
- ❑ **Intrusion detection**
 - ❑ The identification through intrusion signatures and report of intrusion activities
- ❑ **Intrusion prevention**
 - ❑ The process of both detecting intrusion activities and managing automatic responsive actions throughout the network

IDS Components

- ❑ **IDS manager** compiles data from the IDS sensors to determine if an intrusion has occurred.
- ❑ If an IDS manager detects an intrusion, then it sounds an **alarm**.



Possible Alarm Outcomes

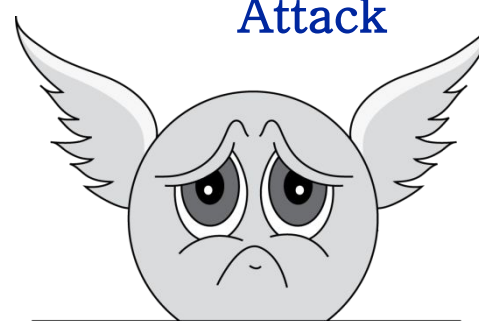
- Alarms can be sounded (positive) or not (negative)

Intrusion

No Intrusion

Attack

Attack



NYPD
03539480

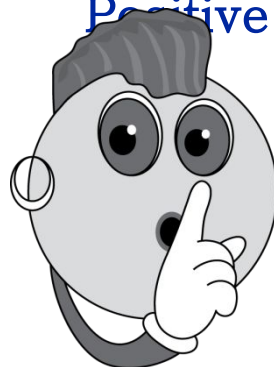
NYPD
03539480

True

False

Positive

Positive



False

True

Negative

Negative

Bad
(reject
normal)

Bad
(miss
attack)

No
Alarm
Sounded

The Base-Rate Fallacy

- ❑ true-positive rate is conflict with false-negative rate.
 - ❑ There is a trade-off
- ❑ If # of intrusions $\ll$ # of all events, the effectiveness of an intrusion detection system can be reduced.
- ❑ In particular, the effectiveness of some IDSs can be misinterpreted due to a statistical error known as the **base-rate fallacy**.
- ❑ This type of error occurs when the probability of some conditional event is assessed without considering the “base rate” of that event.

Base-Rate Fallacy Example

- ❑ Suppose an IDS has 1% chance of false positives, and 1% of false negatives. Suppose further...
 - ❑ An intrusion detection system generates 1,000,100 log entries.
 - ❑ Only 100 of the 1,000,100 entries correspond to actual malicious events.
- ❑ Among the 100 malicious events, 99 will be detected as malicious, which means we have **1 false negative**.
- ❑ Among the 1,000,000 benign events, 10,000 will be mistakenly identified as malicious. That is, we have **10,000 false positives!**
- ❑ Thus, there will be 10,099 alarms sounded, 10,000 of which are false alarms. That means false alarm rate is roughly 99%!

Types of Intrusion Detection Systems

❑ **Rule-Based Intrusion Detection**

- ❑ Rules and signatures identify the types of actions that match certain known profiles for an intrusion attack
- ❑ Alarm raised can indicate what attack triggers the alarm
- ❑ **Problem:** Cannot deal with unknown attacks

❑ **Statistical Intrusion Detection**

- ❑ Statistical representation (**profile**) of the typical ways that a user acts or a host is used
- ❑ Determine when a user or host is acting in highly unusual, anomalous ways.
- ❑ Alarm when a user or host deviates significantly from the stored profile for that person or machine
- ❑ **Problem:** High false positive rate, cannot tell which attack triggers the alarm

Port Scanning

- ❑ Purpose: Attackers need to know where a potential target is
- ❑ TCP scan: use OS system call to check if TCP connection can be set up on a target machine on any port
 - ❑ Example scanner: nmap
 - ❑ See how nmap works on department eustis machine!
- ❑ SYN scan: low-level TCP program to send out SYN packet without intent to finish the TCP connection setup
 - ❑ On receiving SYN/ACK, issues a RST packet to terminate

Port Scanning

- ❑ **Two port scanning mode:**
 - ❑ Vertical scan: target numerous destination ports on a singular host (e.g., nmap)
 - ❑ Horizontal scan: target the same port on many target hosts, effectively looking for a specific vulnerability
 - ❑ E.g., worm
 - ❑ E.g., attacker conduct reconnaissance before real attack